

Nexus OY: Penetration Test Scope and Rules of Engagement

Executive Summary

This document outlines the scope and rules of engagement for the security assessment of Nexus OY, an online retail enterprise. The assessment focuses on evaluating the security posture of their warehousing and shipping IT infrastructure to identify vulnerabilities that could lead to unauthorized access or disruption of operations, with particular attention to ransomware threats.

1. Client Information

Company: Nexus OY

Industry: Online Retail/E-commerce

Primary Business: Online retail enterprise with customer-facing e-commerce sites hosted on Amazon and in-house operations for communications, warehousing, and shipping IT services

Data Center Location: Pori, FI

2. Assessment Objectives

The primary objectives of this security assessment are to:

- Evaluate the security controls that prevent attackers who gain access to warehouse end-user accounts/computers from:
 - Obtaining administrator access to servers
 - Accessing the production inventory database
- Identify and document vulnerabilities in software, operating systems, and applications
- Test the organization's resilience against ransomware attacks targeting production inventory systems
- Assess the effectiveness of security controls protecting warehouse and shipping systems

3. Scope Definition

3.1 In-Scope Systems

System/Component	Description	Testing Approach
Operations Cluster	Servers supporting warehouse operations	Vulnerability assessment, penetration testing
Logistics Cluster	Servers supporting shipping operations	Vulnerability assessment, penetration testing
SQL Server Database	Inventory control system database	Testing against development mirror only
Warehouse Administration Systems	End-user systems with access to operations	Access control testing, privilege escalation
Employee Email	Staff communications	Social engineering assessment

3.2 Out-of-Scope Systems

System/Component	Justification
Amazon Storefront Data	Critical business system, disruption could impact revenue
Amazon Support Cluster	Direct connection to customer-facing systems
Production SQL Server	Direct testing could disrupt operations (mirror provided)
External DNS Server	Outside the focus area of warehouse/shipping systems

3.3 Network Environment

- **Server Infrastructure:** 25 servers segregated into four clusters (administration, operations, logistics, Amazon support)
- **Remote Access:** SSL or IPsec VPN

- **Internet Connectivity:** Dual ISP configuration (one dedicated to Amazon communications)
- **Internal DNS:** Microsoft Active Directory services
- **External DNS:** Linux server in separate DMZ
- **Database:** Microsoft SQL Server hosted on separate SAN

4. Rules of Engagement

4.1 Testing Timeline

- **Project Start:** Two weeks after contract and NDA signing
- **Duration:** 60 days total
- **Milestones:**
 - Week 1: Initial reconnaissance and setup
 - Weeks 2-7: Core testing activities
 - Week 8: Validation and report preparation
- **Deliverables:** Final report due within 60 days of project start

4.2 Testing Methodology

The assessment will follow industry-standard methodologies:

- NIST SP 800-115 Technical Guide to Information Security Testing and Assessment
- OWASP Testing Guide (for application components)

4.3 Testing Approach

- **Black Box Testing:** Limited information provided to simulate real-world attacker perspective
- **Grey Box Testing:** Some information provided about internal architecture to focus testing efforts

4.4 Testing Windows

Test Type	Permitted Timeframe	Restrictions
-----------	---------------------	--------------

Non-disruptive Testing	Normal business hours	Minimal impact on operations
Load Testing	2:00 AM - 6:00 AM on Fri, Sat, Sun	Scheduled maintenance windows only
DoS Simulations	2:00 AM - 6:00 AM on Fri, Sat, Sun	Scheduled maintenance windows only
Social Engineering	Business hours	Email phishing only

4.5 Testing Origin

- Internal testing will originate from an isolated VLAN within Nexus IT department
- Specific IP range to be provided by client IT team

4.6 Security Controls Awareness

The following security controls may impact testing:

- Firewall with integrated IDS between datacenter and corporate LAN
- Local firewalls on each server
- VPN access restrictions
- No HTTP access permitted to operations/logistics clusters
- Servers in operations/logistics clusters have limited internet access

4.7 Allowed Testing Techniques

Technique	Limitations
Vulnerability Scanning	Must throttle to minimize impact
Network Penetration Testing	From IT department VLAN only
Social Engineering	Limited to provided email addresses
Access Control Testing	No disruption to production systems
Privilege Escalation Testing	Must not affect system integrity

Database Security Testing Development mirror only

4.8 Prohibited Testing Techniques

- Denial of Service outside maintenance windows
- Data exfiltration of actual customer/business data
- Testing of Amazon-connected systems
- Testing against production SQL Server
- Destructive testing without explicit approval
- Physical security testing

4.9 Communication Plan

- **Weekly Updates:** Status reports and teleconference with primary contacts
- **Vulnerability Disclosure:** Critical findings reported immediately to IT Director
- **Escalation Path:** IT Director > Warehouse/Operations Manager > CEO
- **Emergency Contact:** IT Director (contact details to be provided)

4.10 Awareness and Notification

- Only IT staff responsible for monitoring operations and logistics systems will be notified
- End users will not be informed of testing activities
- Social engineering targets will not be pre-notified

4.11 Sensitive Data Handling

- All client data handled according to NDA terms
- Testing artifacts stored in encrypted storage
- Client data sanitized from all reports
- Findings tracked in secure, access-controlled system

5. Contacts and Communication

5.1 Client Contacts

- **Primary Technical Contact:** IT Director
- **Business Contacts:** Warehouse Manager, Operations Manager
- **Emergency Contact:** IT Director

5.2 Testing Team Contacts

- **Lead Penetration Tester:** Muhammad Saeed
- **Project Manager:** Syed Abdulbasit
- **Technical Escalation:** Hamza Jalal

5.3 Incident Response Procedure

1. Immediately stop testing activities related to the incident
2. Document the circumstances and findings
3. Contact the IT Director via agreed communication channel
4. Follow client's direction regarding continuation of testing
5. Document the incident resolution in the weekly report

6. Deliverables

6.1 Weekly Status Reports

- Summary of activities completed
- Preliminary findings
- Planned activities for next week
- Issues/blockers requiring client input

6.2 Final Report

- Executive summary for management
- Technical findings with risk ratings
- Reproduction steps for vulnerabilities

- Remediation recommendations
- Supporting evidence and data

7. Legal and Compliance Considerations

7.1 Authorization

- Formal written authorization required before testing begins
- Out-of-scope testing requires additional written approval

7.2 Confidentiality

- All findings and client information protected under NDA
- No disclosure to third parties without written client approval

7.3 Compliance Requirements

- Testing activities comply with applicable laws and regulations
- Testing methodology aligned with industry standards

7.4 Limitation of Liability

- Testing team not responsible for system outages resulting from standard testing procedures
- Client assumes responsibility for production system stability

Approval:

	Name	Signature	Date
Client Representative			
Testing Team Lead			
IT Director			

This document serves as the formal agreement regarding the scope and rules of engagement for the security assessment of Nexus OY's systems. Any modifications to this document must be approved in writing by all parties.

Document Version: 1.0

Last Updated: 10.04.2025